

ENTERPRISE CYBERSECURITY GOVERNANCE FRAMEWORK

Atlas Industrial Machinery Group (AIMG) Public Portfolio Edition · Version 1.0

AIMG is a fictional organization created for professional portfolio and learning purposes. This public edition demonstrates the governance model and core working papers without claiming real organizational approval or deployment.

Executive Summary

The AIMG Enterprise Cybersecurity Governance Framework demonstrates a business-led approach to directing and overseeing cybersecurity across a multinational hybrid IT/OT environment. It connects business criticality, Crown Jewels, CIA requirements, resilience, accountability, risk decisions, policy and control governance, management metrics, assurance and governance maturity.

Organization Facts

Category	Assumption
Organization	Atlas Industrial Machinery Group (AIMG)
Industry	Heavy Equipment Manufacturing
Headquarters	USA
Operations	USA, UAE, India, Europe and Asia
Employees	25,000
Manufacturing Plants	12
IT Assets	15,000
OT Assets	5,000
Azure Subscriptions	20
Critical Applications	100
Third-Party Vendors	500
Data Centers	3
SOC	24x7
Environment	Hybrid IT + OT

Critical Business Processes

Process	System	Business Owner	Criticality	Business Impact
Manufacturing	MES / OT	VP Manufacturing / Plant Operations	Critical	Production disruption or shutdown, delayed customer orders, financial impact, and potential operational or safety consequences.
Finance	ERP	Chief Financial Officer (CFO)	Critical	Disruption to financial transactions, invoicing, payments and reporting, with financial and compliance impact.
Supply Chain	ERP	Chief Supply Chain Officer (CSCO)	Critical	Supplier, inventory, procurement and logistics disruption causing shortages, production delay and customer delivery impact.
Product Engineering	PLM	VP Engineering / R&D;	High	Engineering and product-development disruption with intellectual-property, timeline and competitive impact.
Sales	CRM	Chief Sales Officer (CSO)	High	Customer management and sales disruption affecting quotations, service, revenue and customer satisfaction.
Email & Collaboration	Microsoft 365	CIO	High	Loss of enterprise communication and collaboration, reducing productivity and coordination.
IT Service Management	ServiceNow	CIO	High	Disruption to incident, request, change and problem management, slowing service restoration.
Human Resources	HR System	Chief Human Resources Officer (CHRO)	Medium	Payroll, recruitment and employee-service disruption while core production can generally continue.

Crown Jewels

Asset	Asset Type	Business Process	Business Owner	Why Critical
MES	Application / OT	Manufacturing	VP Manufacturing / Plant Operations	Supports manufacturing operations and production execution.
Manufacturing OT / ICS Environment	OT Infrastructure	Manufacturing	VP Manufacturing / Plant Operations	Supports industrial control and production; compromise can create operational and safety consequences.
ERP	Application	Finance / Supply Chain	CFO / CSCCO	Supports critical financial, procurement, inventory and supply-chain operations.
PLM	Application / Information	Product Engineering	VP Engineering / R&D;	Supports product development and critical engineering information.
Engineering Design Repository	Information / Data	Product Engineering	VP Engineering / R&D;	Contains engineering designs, technical documentation and intellectual property.
CRM	Application / Information	Sales	CSO	Supports customer management, sales operations, opportunities and customer information.
Microsoft Entra ID	Identity / Security Platform	Enterprise-wide	CIO	Controls enterprise identities and access to critical applications, cloud resources and corporate services.
Customer & Business Data	Information / Data	Enterprise-wide	Relevant Business Function Owner	Contains sensitive customer and business information requiring protection.

CIA Assessment

Asset	Type	Process	Owner	C	I	A	Justification
MES	Application / OT	Manufacturing	VP Manufacturing / Plant Operations	High	High	High	Production execution and operational information require strong protection and availability.
Manufacturing OT / ICS Environment	OT Infrastructure	Manufacturing	VP Manufacturing / Plant Operations	Medium	High	High	Integrity and availability are essential to safe, continuous industrial operations.
ERP	Application	Finance / Supply Chain	CFO / CSCO	High	High	High	Financial, procurement, inventory and supply-chain records require confidentiality, accuracy and availability.
PLM	Application / Information	Product Engineering	VP Engineering / R&D;	High	High	Medium	Sensitive engineering data requires confidentiality and integrity; short outages may delay engineering work.
Engineering Design Repository	Information / Data	Product Engineering	VP Engineering / R&D;	High	High	Medium	Engineering intellectual property and designs require strong confidentiality and integrity.
CRM	Application / Information	Sales	CSO	High	High	Medium	Customer and sales information requires protection against disclosure and modification.
Microsoft Entra ID	Identity / Security Platform	Enterprise-wide	CIO	High	High	High	Enterprise identity and access depend on confidentiality, integrity and high availability.
Customer & Business Data	Information / Data	Enterprise-wide	Relevant Business Function Owner	High	High	Medium	Sensitive customer and business information creates privacy, contractual, financial and reputation exposure.

Recovery Requirements

Asset	Recovery Tier	RTO	RPO	Recovery Rationale
MES	Tier 1 - Mission Critical	2 Hours	15 Minutes	Directly supports manufacturing execution; prolonged outage can stop production.
Manufacturing OT / ICS Environment	Tier 1 - Mission Critical	2 Hours	15 Minutes	Industrial control outage can stop production and create operational or safety consequences.
ERP	Tier 1 - Mission Critical	2 Hours	15 Minutes	Critical finance, procurement, inventory and supply-chain dependency.
PLM	Tier 3 - Important	8 Hours	4 Hours	Outage delays engineering and product development but is less likely to immediately stop enterprise operations.
Engineering Design Repository	Tier 3 - Important	8 Hours	4 Hours	Outage delays engineering; data loss or corruption can affect accuracy and project timelines.
CRM	Tier 2 - Business Critical	4 Hours	1 Hour	Extended outage disrupts sales, customer engagement and revenue generation.
Microsoft Entra ID	Tier 1 - Mission Critical	2 Hours	15 Minutes	Identity outage can block access to critical applications and cloud resources enterprise-wide.
Customer & Business Data	Tier 2 - Business Critical	4 Hours	1 Hour	Data supports multiple functions and loss can create financial, contractual, privacy and reputation impact.

Recovery targets are portfolio assumptions and should be validated through formal Business Impact Analysis with relevant Business Owners, system owners, IT, OT and business-continuity stakeholders.

1. Organization Profile

AIMG is a fictional multinational heavy-equipment manufacturer operating across the USA, UAE, India, Europe and Asia. The governance design assumes a hybrid IT and OT environment with globally distributed business operations, manufacturing plants, Azure services, enterprise applications, identity platforms and third-party dependencies.

2. Business Context & Criticality

Cybersecurity priorities are anchored in business consequences rather than technical severity alone. Criticality considers financial, operational, customer, legal or regulatory, safety and reputation impact. Business Owners provide context and remain accountable for business outcomes.

3. Cybersecurity Governance Model

The model separates executive oversight, business-risk ownership, cybersecurity oversight, technical implementation and independent assurance. Risk decisions are made at the appropriate authority level and material risks, incidents, exceptions and unresolved issues are escalated based on business impact and risk severity.

4. Policy & Control Governance

AIMG uses a hierarchy of policies, standards, procedures and guidelines. Policies and controls have defined ownership, approval, review, exception and waiver processes. Control effectiveness is monitored and deficiencies are tracked to remediation or formal risk acceptance.

5. Cybersecurity Risk Governance

Risk governance covers identification, inherent risk, control effectiveness, residual risk, treatment, acceptance, risk-register governance, monitoring, reporting and escalation. Risk Owners approve treatment or residual-risk acceptance within delegated authority and tolerance.

6. Performance, Metrics & Management Reporting

KPIs, KRIs and KGIs provide measurable visibility of security performance and risk. Management reporting uses defined thresholds, RAG status, data-quality validation, escalation triggers and action ownership. Example metric: Critical Vulnerability SLA Compliance target $\geq 95\%$, with management attention below 90%.

7. Assurance, Audit & Compliance

The assurance model maintains independence between control operation, oversight and audit. Findings are severity-rated, assigned to accountable owners, tracked through remediation and validated before closure. Legal, regulatory, contractual and certification obligations are incorporated into governance reporting.

8. Governance Maturity & Continuous Improvement

Governance maturity is assessed from Level 1 Initial through Level 5 Optimized across accountability, risk, policy, incident management, vulnerability management, IAM/PAM, OT, third-party risk, resilience, metrics, assurance and continuous improvement. The framework is reviewed at least annually and after material change.

Governance RACI

#	Governance Activity	Exec	CIO	InfoSec	Steer	Business	Risk	IT/OT	Legal	Audit
1	Approve Cybersecurity Strategy	A	C	R	C	C	I	I	C	I
2	Approve Cybersecurity Policies	I	A	R	C	C	C	C	C	I
3	Cybersecurity Risk Assessment & Reporting	I	A	R	C	C	C	C	C	I
4	Approve Risk Treatment / Risk Acceptance	I	C	R	C	C	A	C	C	I
5	Implement Cybersecurity Controls & Remediation	I	A	C	I	C	C	R	I	I
6	Security Incident Management & Escalation	I	C	A	I	C	I	R	C	I
7	Vulnerability Management & Remediation Governance	I	C	A	I	C	C	R	I	I
8	Access Management & Privileged Access Governance	I	A	R	I	C	C	R	C	I
9	Third-Party Cybersecurity Risk Governance	I	C	R	C	A	C	C	C	I
10	KPI/KRI Monitoring & Executive Reporting	I	A	R	C	C	C	C	C	I
11	Coordinate Cybersecurity Audit Finding Remediation	I	C	A	C	C	C	R	C	C
12	Business Continuity / Cyber Resilience Governance	I	C	C	C	A	C	R	C	I
13	Policy Exception & Security Waiver Governance	I	C	R	C	C	A	C	C	I
14	Cybersecurity Architecture / Major Technology Change Review	I	A	R	C	C	C	R	C	I

Governance Decision Lifecycle

01 Identify — Business context, assets and risks.

02 Assess — Impact, CIA, controls and residual risk.

03 Decide — Treatment, acceptance and escalation.

04 Measure — KPIs, KRIs, KGIs and RAG reporting.

05 Assure — Audit, compliance, maturity and review.

Management Takeaway

Risk decisions stay visible and measurable when accountability, decision authority, escalation triggers, metrics, assurance and periodic review operate as one governance system.